

Relatório do trabalho de grupo

Proposta de controlo de acessos para mini-servidor Linux

1. Identificação do grupo

Campo	Informação
Grupo	Grupo 1 - Segurança de Sistemas Linux
Elementos	Eliézer Santos; Kleiton Renato; João Sousa; Cláudio Tavares
Papéis assumidos	Administração do sistema; operação web; auditoria; documentação e validação das evidências.

2. Síntese do cenário

A equipa prepara um mini-servidor Ubuntu Linux numa máquina virtual VMware para alojar uma aplicação web. O servidor será utilizado por perfis com necessidades diferentes: administrador do sistema, operador web, auditor e visitante técnico. O problema central é evitar conta partilhada, permissões excessivas, uso frequente da conta root, acesso SSH sem regras e exposição de ficheiros sensíveis. A proposta aplica IAM, grupos Linux, permissões, menor privilégio e regras de acesso remoto seguro para tornar o ambiente organizado, rastreável e justificável.

3. Perfis, grupos e responsabilidades

Perfil	Grupo sugerido	Responsabilidades	Permissões necessárias	Permissões a evitar
Administrador do sistema	admins	Gerir utilizadores, grupos, permissões, serviços, atualizações e backups.	sudo controlado; gestão de contas e serviços; leitura administrativa quando necessário.	Login direto como root; partilha de credenciais; permissões administrativas para outros perfis.
Operador web	webops	Publicar e atualizar ficheiros da aplicação web.	Escrita em public e leitura da documentação autorizada.	Acesso a config, logs sensíveis, sudo e alteração de permissões do sistema.
Auditor	auditores	Consultar evidências, registos e documentação.	Leitura de logs e docs, sem poder alterar ficheiros.	Escrita em logs; acesso a segredos; alteração da aplicação; sudo.
Visitante técnico	visitantes	Consultar apenas informação pública ou documentação autorizada.	Leitura limitada de docs e, se necessário, conteúdo público.	SSH administrativo; sudo; config; logs internos; qualquer escrita.

4. Estrutura de diretórios proposta

Estrutura sugerida para separar conteúdo público, configuração sensível, registos e documentação:

```
/opt/projeto-web/
|-- public/ -> ficheiros públicos da aplicação web
|-- config/ -> ficheiros de configuração e parâmetros sensíveis
|-- logs/   -> registos de acesso, erros e evidências
`-- docs/   -> documentação autorizada do projeto
```

Diretório	Conteúdo	Quem pode ler	Quem pode escrever	Restrição principal
public/	HTML, CSS, JavaScript, imagens e ficheiros servidos pela aplicação.	Todos podem ler o conteúdo público.	webops e admins.	Não guardar segredos nem ficheiros internos.

config/	Configurações, variáveis de ambiente, credenciais técnicas e parâmetros de serviço.	Apenas admins; a aplicação só se necessário e por regra específica.	admins.	webops, auditores e visitantes não devem aceder.
logs/	Registos de funcionamento, acessos, erros e evidências.	auditores e admins.	serviço/aplicação e admins; auditores apenas leem.	visitantes e webops não devem consultar logs internos.
docs/	Manuais, procedimentos, matriz de acessos e evidências autorizadas.	visitantes, auditores, webops e admins, quando autorizado.	admins ou responsável definido.	Não publicar passwords, chaves, tokens ou configurações sensíveis.

Se as permissões forem excessivas, um utilizador pode modificar a aplicação, apagar evidências, ler segredos ou comprometer o servidor. Por isso, cada pasta recebe apenas as permissões indispensáveis à sua função.

5. Proposta de permissões

Caminho	Dono/grupo sugerido	Permissão sugerida	Justificação
/opt/projeto-web	root:admins	755	Permite atravessar a pasta principal e aplicar controlo real nas subpastas; apenas root/admins gerem a estrutura.
/opt/projeto-web/public	root:webops	2775	webops pode publicar; setgid mantém o grupo nos novos ficheiros; conteúdo público pode ser lido.
/opt/projeto-web/config	root:admins	750; ficheiros 640	Protege configurações e possíveis credenciais; acesso apenas a administradores.
/opt/projeto-web/logs	root:auditores	750; ficheiros 640	Auditores consultam evidências em só-leitura; escrita fica restrita ao serviço/admins.
/opt/projeto-web/docs	root:visitantes	750; ficheiros 640	Visitantes consultam documentação autorizada; escrita não é permitida ao perfil visitante.

Comandos exemplificativos para aplicar na VM Ubuntu Server:

```
sudo groupadd admins
sudo groupadd webops
sudo groupadd auditores
sudo groupadd visitantes
sudo adduser admin1; sudo adduser operador1
sudo adduser auditor1; sudo adduser visitante1
sudo usermod -aG admins admin1
sudo usermod -aG webops,visitantes operador1
sudo usermod -aG auditores,visitantes auditor1
sudo usermod -aG visitantes visitante1
sudo mkdir -p /opt/projeto-web/{public,config,logs,docs}
sudo chown root:admins /opt/projeto-web && sudo chmod 755 /opt/projeto-web
sudo chown -R root:webops /opt/projeto-web/public
sudo chmod 2775 /opt/projeto-web/public
sudo chown -R root:admins /opt/projeto-web/config && sudo chmod 750 /opt/projeto-web/config
sudo chown -R root:auditores /opt/projeto-web/logs && sudo chmod 750 /opt/projeto-web/logs
sudo chown -R root:visitantes /opt/projeto-web/docs && sudo chmod 750 /opt/projeto-web/docs
sudo find /opt/projeto-web -type f -exec chmod 640 {} \;
```

6. Regras de acesso remoto por SSH

Perfil	Pode aceder por SSH?	Tipo de autenticação	Justificação
Administrador	Sim	Conta individual, chave SSH com passphrase e sudo controlado.	Precisa administrar o servidor; root direto deve ser bloqueado.
Operador web	Sim, se necessário	Chave SSH; sem sudo; acesso limitado à publicação.	Precisa atualizar public, mas não administrar o sistema.
Auditor	Sim, se necessário	Chave SSH; sem sudo; acesso de leitura.	Consulta logs e evidências sem alterar o ambiente.
Visitante técnico	Não	Não aplicável.	Deve consultar apenas documentação autorizada, sem acesso ao sistema operativo.

As contas devem ser individuais, nunca partilhadas. Chaves privadas, passphrases, passwords, tokens, ficheiros .env e conteúdos sensíveis de /etc/shadow ou config nunca devem ser publicados como evidência. Se todos tiverem acesso administrativo, perde-se a separação de funções e uma conta comprometida pode comprometer todo o servidor.

Configuração recomendada em /etc/ssh/sshd_config.d/99-iam-atividade.conf:

```
PermitRootLogin no
PubkeyAuthentication yes
PasswordAuthentication no # aplicar depois de testar as chaves SSH
AllowGroups admins webops auditores
MaxAuthTries 3
LoginGraceTime 30
sudo /usr/sbin/sshd -t
sudo systemctl reload ssh
```

7. Riscos e medidas de mitigação

Risco	Impacto	Medida de mitigação
Todos usarem a mesma conta	Sem rastreabilidade; não é possível saber quem executou cada ação.	Criar contas individuais e associar cada utilizador ao grupo correto.
Uso frequente da conta root	Erros ou ataques podem causar controlo total do servidor.	Bloquear root por SSH e usar sudo apenas para admins.
Permissões excessivas em public ou config	Alteração indevida da aplicação ou exposição de credenciais.	Aplicar chmod/chown por diretório e seguir menor privilégio.
SSH sem regras claras	Acesso remoto indevido, força bruta e aumento da superfície de ataque.	Usar AllowGroups, chaves SSH, limite de tentativas e revisão de acessos.
Logs alteráveis por qualquer utilizador	Perda ou adulteração de evidências.	Permitir leitura aos auditores e restringir escrita aos serviços/admins.
Falta de documentação	Dificulta manutenção, auditoria e responsabilização.	Manter matriz de acessos, papéis e comandos aplicados em docs.

8. Conclusão

A proposta substitui o uso de conta única e privilégios generalizados por contas individuais, grupos funcionais e permissões coerentes com as responsabilidades de cada perfil. A estrutura /opt/projeto-web separa ficheiros públicos, configurações, logs e documentação, reduzindo o risco de exposição de dados sensíveis e de alterações não autorizadas. O acesso remoto por SSH fica limitado aos perfis que realmente necessitam, com root bloqueado, grupos autorizados e preferência por chaves SSH. Assim, o mini-servidor Linux fica mais seguro, auditável e alinhado com o princípio do menor privilégio.

Evidências sugeridas para anexar ao PDF

```
id admin1; id operador1; id auditor1; id visitante1
ls -ld /opt/projeto-web /opt/projeto-web/*
```

```
tree -pug /opt/projeto-web  
sudo -u operador1 touch /opt/projeto-web/public/teste.html  
sudo -u visitante1 cat /opt/projeto-web/config/app.conf  
# esperado: Permission denied  
grep -R -E 'PermitRootLogin|AllowGroups|PasswordAuthentication' /etc/ssh/sshd_config.d/*.conf
```